

Rapport de Travaux Pratiques – Séance 10

Invocation d’Objets Distants (RMI) et Durcissement

Pyro5

Filière Cybersécurité – Cycle Ingénieur 1A
EUROMED Fès

14 juin 2026

Table des matières

1	Introduction et Principes RMI	2
2	Composants de l’Architecture distribuée	2
3	Contrôles de Sécurité Applicative	2
3.1	Politique d’Exposition Minimale	2
3.2	Validation de Types et Assainissement des Chaînes	2
3.3	Masquage des Erreurs et Exceptions Sûres	2
4	Checklist de Conformité de Sécurité	2
5	Conclusion	2

1 Introduction et Principes RMI

L’invocation d’objets distants (RMI - Remote Method Invocation) permet à un programme exécuté sur une machine d’appeler des méthodes sur un objet situé dans un autre espace d’adressage réseau. Ce TP met en œuvre le framework **Pyro5** (Python Remote Objects) et applique un durcissement drastique de sa surface d’attaque.

2 Composants de l’Architecture distribuée

L’architecture logicielle développée comprend quatre composants majeurs :

- **Le Service Distant** (*DocumentService*) : Classe contenant l’état métier.
- **Le Daemon** : Le serveur réseau sous-jacent qui gère les sockets et dispatche les requêtes.
- **Le Name Server** : Registre d’annuaire permettant de lier des noms logiques à des URIs Pyro.
- **Le Proxy** : Pattern de conception instancié côté client pour simuler la présence locale de l’objet distant.

3 Contrôles de Sécurité Applicative

3.1 Politique d’Exposition Minimale

Par défaut, exposer une classe entière est une faille critique. Nous utilisons le décorateur `@Pyro5.api.expose` comme une liste blanche explicite. Les méthodes internes d’administration ou de gestion interne restent invisibles sur le réseau.

3.2 Validation de Types et Assainissement des Chaînes

Pour contrer les attaques de traversée de répertoires (*Path Traversal*), l’identifiant du document transmis est validé par une expression régulière stricte :

$$\text{Regex} = \wedge[\text{a} - \text{zA} - \text{Z0} - \text{9_}]\{1, 32\}\$ \quad (1)$$

Toute entrée ne correspondant pas exactement à ce filtre est immédiatement rejetée avant traitement.

3.3 Masquage des Erreurs et Exceptions Sûres

Les exceptions internes (`KeyError`, `DatabaseError`) révèlent des détails sur l’infrastructure. Le serveur intercepte ces erreurs, écrit la stack-trace dans un fichier journal local sécurisé, et renvoie au client une exception épurée et générique.

4 Checklist de Conformité de Sécurité

- ✓ Sériailiseur **Serpent** activé (Bannissement de `pickle`).
- ✓ Restriction des échanges aux types de données primitifs uniquement.
- ✓ Validation regex des arguments d’entrée.
- ✓ Authentification par jeton partagé à l’entrée des méthodes sensibles.

5 Conclusion

Le paradigme RMI facilite le développement d’applications réparties mais introduit une surface d’attaque importante si le protocole réseau sous-jacent permet la désérialisation d’objets

arbitraires. Le choix de Serpent associé à une liste blanche d'exposition permet de sécuriser efficacement l'architecture.